EECP v2

Kế hoạch chuyển đổi kiến trúc và phân công 3 thành viên

Đánh giá dựa trên sơ đồ mục tiêu, tài liệu mô tả Agent UI/Privileged Service và mã nguồn hiện tại của repository PBL4_EECP.

Kết luận	Không nên viết lại toàn bộ. Giữ nguyên lõi session/policy/ACK/audit và dashboard; chuyển đổi theo một vertical slice: Backend → Local Gateway → Agent Client → IPC → Windows Service → Firewall → ACK/telemetry.

Đã có trong repo

• FastAPI theo Clean Architecture; session, policy version/hash, command retry/ACK và audit hash-chain.

• Agent đăng ký/heartbeat, short-poll command; áp dụng hosts, taskkill và USB; có restore baseline.

• Dashboard React/Vite; WebSocket in-process để báo thay đổi và REST là nguồn dữ liệu chính.

• HTTPS reverse proxy bằng Caddy; test unit/integration tương đối đầy đủ.

Chưa khớp sơ đồ mục tiêu

• `gateway` trong Compose hiện là Caddy reverse proxy, chưa phải Local Gateway theo phòng thi.

• Agent đang là một process; chưa tách user process và Windows Service đặc quyền qua IPC.

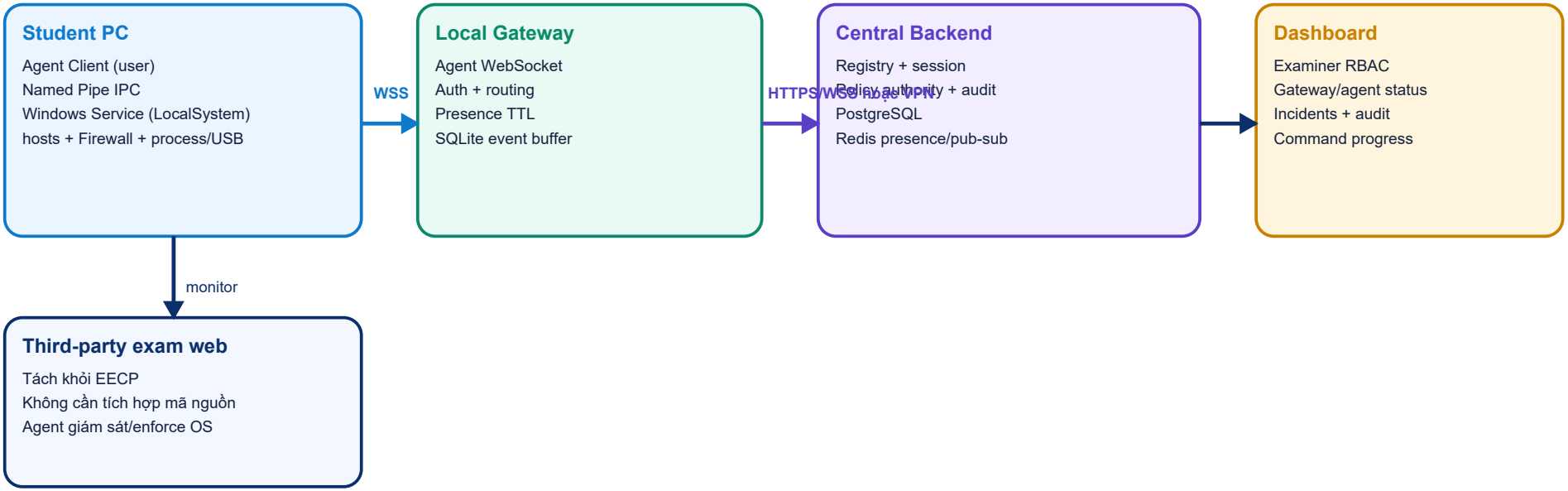
• Chưa có Windows Firewall/WFP enforcement; chặn mạng mới dựa trên hosts.

• Backend còn SQLite, thiếu Redis presence/pub-sub, auth/RBAC và định danh tin cậy cho Agent/Gateway.

Ưu tiên kiến trúc

P0 - phải làm trước	P1 - hoàn thiện MVP	P2 - sau khi demo ổn định
Chốt protocol v2; Local Gateway thật; tách Agent/Service; IPC an toàn; Firewall rule có rollback; E2E vertical slice.	Auth/RBAC; PostgreSQL; Redis presence; event buffer; installer Windows Service; dashboard gateway/agent health.	Custom WFP callout/driver, HA nhiều backend, analytics nâng cao, auto-update/PKI hoàn chỉnh.

1. Kiến trúc đề xuất và ranh giới trách nhiệm



Thành phần	Trách nhiệm	Không được làm
Agent Client (user process)	Kết nối Gateway, hiển thị trạng thái/cảnh báo, giám sát user-level, gửi event; gọi IPC theo contract.	Không nhận lệnh shell tùy ý; không sửa Firewall/registry/hosts trực tiếp.
Privileged Agent Service	Xác minh policy/session; thực thi allowlisted operation; hosts + Firewall + process + USB; lưu baseline và rollback.	Không tin dữ liệu IPC chỉ vì đến từ local; không expose API mạng.
Local Gateway	WSS với Agent; xác thực; routing; presence; buffer khi mất WAN; uplink HTTPS/WSS/VPN đến Backend.	Không trở thành policy authority; không tự sửa policy do Backend phát hành.
Central Backend	Nguồn sự thật cho session/policy/authorization/audit; registry; ingest event; PostgreSQL + Redis.	Không điều khiển trực tiếp OS máy sinh viên; không phụ thuộc browser thi bên thứ ba.
Dashboard	Giao diện Examiner theo RBAC; theo dõi gateway/agent, command/ACK, incident/audit.	Không gọi trực tiếp Gateway/Agent; mọi thao tác đi qua Backend.

Contract v2 nên chốt trước khi code

Message	Trường tối thiểu	Quy tắc
PolicyEnvelope	policy_id, version, hash, session_id, expires_at, rules, signature	Immutable; Service kiểm hash/signature, session và expiry trước khi apply.
Command	command_id, type, target_id, issued_at, deadline, policy_hash	Idempotent; chỉ allowlist APPLY_POLICY, RESTORE_BASELINE, HEALTH_CHECK.
Ack	command_id, status, applied_hash, service_version, error_code	ACK từ Service phải đi ngược Gateway → Backend và được lưu bền vững.
Event	event_id, session_id, agent_id, type, occurred_at, payload	Có sequence/id để dedupe; Gateway buffer và retry khi mất uplink.
Presence	agent_id, gateway_id, last_seen, health, active_policy_hash	TTL ngắn trong Redis; dữ liệu lịch sử quan trọng ghi PostgreSQL/audit.

2. Hướng làm tiếp theo - theo lát cắt chạy được

Thứ tự dưới đây giảm rủi ro bằng cách luôn giữ một luồng có thể demo. Không di chuyển database, thêm Redis, viết Gateway và tách Agent đồng thời trong một PR.

Mốc	Mục tiêu	Việc chính	Cổng nghiệm thu
M0 - Baseline 1-2 ngày	Đóng băng bản đang chạy	Tạo tag/branch baseline; chạy backend tests + frontend build; ghi contract hiện tại; đổi tên Caddy service từ `gateway` thành `edge` để tránh nhầm.	Demo cũ vẫn chạy; CI xanh; không mất thay đổi đang dở trong working tree.
M1 - Protocol + skeleton 2-3 ngày	Tạo ranh giới mới mà chưa enforce thật	Định nghĩa JSON schema/protocol v2; scaffold `apps/gateway`, `agent_client`, `agent_service`; mock IPC và WSS.	Contract tests pass; command đi qua đủ 5 hop và ACK quay về.
M2 - Vertical slice P0 4-6 ngày	Chặn một policy thật	Service apply/restore hosts + một Firewall rule; Named Pipe có ACL; Gateway auth/routing/buffer tối thiểu; Backend route tới gateway.	Chặn domain + direct IP; kill Client không làm mất enforcement; restore idempotent.
M3 - Data + security P1 4-6 ngày	Bền vững và xác thực	PostgreSQL adapter/migration; Redis presence/pub-sub; enrollment credential/mTLS hoặc signed token; RBAC Examiner; event dedupe.	Restart từng thành phần không mất session/command/audit; máy giả không đăng ký được.
M4 - Hardening + demo 3-5 ngày	Đủ tin cậy để trình bày	Installer Windows Service; watchdog/health; offline buffer; dashboard gateway health; VM bypass tests; tài liệu vận hành/rollback.	Chạy 3 lần liên tiếp kịch bản end-to-end; không còn blocker/critical.

Giữ lại và tái sử dụng

- Domain session/policy, policy hash, retry/ACK, audit hash-chain.
- Dashboard hiện có và WebSocket invalidation pattern.
- Enforcer hosts/process/USB, nhưng chuyển vào Service đặc quyền.
- Các integration test API hiện tại làm regression suite.

Thay đổi hoặc bổ sung

- `AgentClient` hiện gọi Backend trực tiếp → gọi Local Gateway qua WSS.
- Short polling → Gateway push command; REST vẫn dùng cho đồng bộ/recovery.
- SQLite central → PostgreSQL sau khi vertical slice ổn định.
- Realtime in-process → Redis pub/sub khi chạy nhiều process/host.

3. Bảng nhiệm vụ cho 3 người

Giả định vai trò: TV1 - Central Backend & Data; TV2 - Local Gateway & Dashboard; TV3 - Windows Agent & Endpoint Security. Thay TV1/TV2/TV3 bằng tên thật khi đưa vào backlog.

ID	Ưu tiên	Chủ trì	Nhiệm vụ / phạm vi file	Đầu ra bắt buộc	Reviewer	Phụ thuộc
C-01	P0	Cả nhóm	Chốt protocol v2, threat model và ADR: policy/command/ack/event/presence; quyết định auth và IPC.	Schema + ví dụ payload + contract tests + ADR	Cả 3	-
B-01	P0	TV1	Backend: gateway registry, agent-to-gateway mapping, route command qua gateway; giữ domain/use case hiện tại.	API + unit/integration tests	TV2	C-01
B-02	P1	TV1	PostgreSQL adapter, migration và dữ liệu seed; không sửa domain để phụ thuộc DB.	Compose + migration + repository tests	TV3	B-01
B-03	P1	TV1	Redis presence/pub-sub, TTL offline, event ingest/dedupe; tách dữ liệu ephemeral và persistent.	Presence service + tests + metrics	TV2	B-01, G-03
B-04	P1	TV1	Auth/RBAC Examiner và credential cho Gateway/Agent; audit mọi thao tác policy/session.	Auth middleware + negative tests	TV3	C-01
G-01	P0	TV2	Scaffold `apps/gateway`; agent WSS server; backend uplink; config theo gateway_id/room.	Gateway chạy độc lập + health endpoint	TV1	C-01
G-02	P0	TV2	Routing command/ACK/event, reconnect/backoff và correlation ID; giữ Backend là authority.	Vertical slice command round-trip	TV3	G-01, B-01
G-03	P1	TV2	Presence và durable event buffer bằng SQLite local; retry + dedupe khi mất uplink.	Offline test + flush event test	TV1	G-02
G-04	P1	TV2	Dashboard: gateway health, agent presence, command progress, buffer backlog; sửa terminology `edge`/`local gateway`.	UI states + typecheck/build	TV3	B-03, G-03
A-01	P0	TV3	Tách `agent_client` (user) và `agent_service` (Windows Service); di chuyển enforcement có quyền cao vào Service.	Hai process chạy độc lập; service lifecycle test	TV1	C-01
A-02	P0	TV3	Named Pipe IPC với ACL; allowlist operation; validation policy/session/hash; chống replay.	IPC contract + malicious-request tests	TV2	A-01
A-03	P0	TV3	Firewall adapter: rule theo IP/CIDR/app/port; giữ hosts như lớp phụ; persist baseline + rollback idempotent.	Direct-IP block + restore tests trên VM	TV1	A-02
A-04	P1	TV3	Installer/service account, recovery/watchdog, health telemetry; bảo đảm kill Client không tắt enforcement.	Installer script/MSI plan + failure tests	TV2	A-01..03
C-02	P0	Cả nhóm	E2E: Backend → Gateway → Client → IPC → Service → Firewall → ACK/telemetry → Dashboard.	Script demo lặp lại được + log/correlation	Cả 3	B-01, G-02, A-03
C-03	P1	Cả nhóm	Hardening: mất mạng, restart, duplicate, timeout, policy hết hạn, gateway offline, máy giả mạo.	Test matrix và biên bản 3 lần chạy	Cả 3	B/G/A P1

4. Kế hoạch phối hợp theo sprint

Sprint	TV1 - Backend & Data	TV2 - Gateway & Dashboard	TV3 - Agent & Security	Demo cuối sprint
S0 Contract	Gateway registry contract; API compatibility; ADR data/auth.	Gateway skeleton; WSS mock; message router mock.	Client/Service skeleton; IPC mock; service lifecycle.	Command giả đi đủ luồng và ACK về Backend.
S1 Vertical slice P0	Route command qua gateway; persist command/audit; API tests.	WSS agent + uplink; reconnect; routing/correlation.	Named Pipe; chuyển hosts/process/USB; Firewall adapter đầu tiên.	Chặn domain và direct IP; restore; kill Client không mất rule.
S2 Resilience P1	PostgreSQL; Redis presence/pub-sub; event dedupe.	SQLite buffer; offline replay; presence heartbeat; dashboard gateway health.	Installer Service; signed policy validation; watchdog/health telemetry.	Mất WAN 2 phút, event không mất và tự flush khi nối lại.
S3 Security & release	RBAC, agent/gateway credential, audit/report; migration rehearsal.	UI error/offline/backlog states; metrics/log; runbook gateway.	Bypass/failure tests; rollback; service recovery; packaging.	E2E 3 lần, checklist release, video dự phòng.

Quy tắc chia PR

• Một PR chỉ có một mục tiêu; ưu tiên dưới khoảng 400 dòng thay đổi thuần.

• Contract/schema merge trước implementation; consumer test chạy ở cả Gateway và Agent.

• TV1 review TV2, TV2 review TV3, TV3 review TV1; PR bảo mật cần hai reviewer.

• Không sửa trực tiếp phần enforcement trên máy thật nếu chưa có restore test trong VM.

• Mỗi sprint phải có demo trên `main`, không chỉ demo branch cá nhân.

• Giữ regression suite cho luồng hiện tại cho đến khi v2 đạt feature parity.

Definition of Done cho từng work package

Bắt buộc	Nội dung
Contract	Schema/versioning rõ; lỗi có mã; tương thích hoặc có migration plan.
Test	Happy path + lỗi quan trọng + retry/idempotency; riêng Agent phải có VM integration test.
Security	Không có arbitrary command; xác thực identity; secret không nằm trong repo/log; quyền tối thiểu.
Operations	Health check, structured log, correlation_id, rollback/recovery và hướng dẫn chạy.
Review	PR được reviewer khác approve; checks pass; tài liệu/sơ đồ khớp code.

5. Tiêu chí nghiệm thu và rủi ro

Kịch bản nghiệm thu bắt buộc

• Examiner tạo session và deploy policy từ Dashboard.

• Backend phát PolicyEnvelope; Local Gateway chuyển đúng Agent; ACK đúng hash quay về.

• Service áp hosts và Firewall; domain bị chặn, direct IP cũng bị chặn.

• Sinh viên kill Agent Client: Firewall/hosts vẫn còn; Service phát health event.

• Gateway mất uplink: event được buffer; nối lại thì gửi đủ, không trùng.

• Kết thúc session: restore baseline; chỉ xóa rule EECP, không ảnh hưởng rule ngoài.

• Dashboard hiển thị gateway/agent/policy/incident/audit nhất quán.

Bài kiểm thử bypass/failure

• Sửa/xóa hosts, đổi DNS, truy cập thẳng IP, dùng subdomain.

• Gửi IPC lệnh ngoài allowlist, replay command cũ, sửa policy hash.

• Restart Service/Client/Gateway/Backend giữa lúc RUNNING.

• Command trùng, ACK trùng, event out-of-order, clock lệch nhẹ.

• Gateway offline, buffer đầy, PostgreSQL/Redis tạm lỗi.

• Agent ID giả, token/cert hết hạn, Examiner không đủ role.

Rủi ro	Mức	Giảm thiểu
Viết custom WFP driver quá sớm	Cao	MVP dùng Windows Firewall adapter; chỉ đánh giá callout driver sau khi có threat model và test signing/driver.
Local Gateway bị nhầm với Caddy	Cao	Đổi Compose service Caddy thành `edge`; Local Gateway là app riêng có gateway_id/room và state riêng.
Agent Service trở thành local root API	Cao	Named Pipe ACL + allowlist operation + signed policy + replay protection; tuyệt đối không chạy shell từ payload.
Chuyển PostgreSQL/Redis làm chậm vertical slice	Trung bình	Giữ port/repository; hoàn tất command round-trip trước, rồi thay adapter dữ liệu.
Rule mạng làm mất kết nối quản trị	Cao	Allowlist Backend/Gateway/DNS/NTP trước deny; transaction + timeout rollback + rule prefix riêng.
Dynamic IP/CDN làm policy domain sai	Trung bình	Hosts vẫn chặn domain; Firewall chỉ dùng CIDR/IP được quản trị; ghi rõ giới hạn và tránh block dải CDN rộng trong MVP.
Working tree hiện đang có thay đổi chưa commit	Trung bình	Tạo branch/tag baseline sau khi review thay đổi; không reset/ghi đè; PR tách theo work package.

Bước đầu tiên ngày mai

Họp 60-90 phút để chốt C-01, sau đó mỗi người mở một PR skeleton song song: TV1 gateway registry contract, TV2 `apps/gateway`, TV3 `agent_service` + Named Pipe mock. Cuối ngày phải demo command round-trip giả; chưa đụng PostgreSQL/Redis/WFP driver.